

Cisco Secure Workload - FedRAMP Compliance Report

Cisco Secure Workload - FedRAMP Compliance Report

Customer-Facing Compliance Report

Framework: FedRAMP (Moderate baseline) - Federal Risk and Authorization Management Program

Primary audience: Cloud service providers seeking or maintaining FedRAMP authorisation, federal agency customers, and 3PAOs preparing assessment evidence.

CSW positioning: Information-flow enforcement (AC-4), boundary protection (SC-7), continuous monitoring evidence (CA-7), and system monitoring (SI-4) at the workload layer.

Framework Version Note

FedRAMP baselines are aligned to NIST SP 800-53 Rev. 5 (Low, Moderate, High). This report assumes the Moderate baseline as the most common cloud-service scope. Control IDs referenced (e.g. AC-4, SC-7, SI-4, CA-7) are stable in 800-53 Rev. 5. Validate the customer's authorisation level and parameter tailoring against the SSP.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The reference design (CSW-FedRAMP-Technical-Reference design.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

FedRAMP

- |— Authorisation-Boundary (in-scope workloads inside the SSP boundary)
- |— External-Connections (external systems and interconnections)
- |— Privileged-Operations (jump hosts, admin paths)
- |— ConMon-Telemetry-Sources

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- AC-4 - Information Flow Enforcement (workload-to-workload)
- SC-7 - Boundary Protection (workload-to-workload)
- AU family - Audit and Accountability (workload telemetry)
- SI-4 - System Monitoring (workload telemetry)
- CA-7 - Continuous Monitoring (technical telemetry)
- RA-5 / SI-2 - Vulnerability Scanning and Flaw Remediation (reachability-weighted)

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- AC-1 through AC-3 - Identity-layer access enforcement
- Encryption controls (SC-8 / SC-13) - CSW detects plaintext flows but does not enforce encryption
- Personnel security (PS family), physical security (PE family)
- FedRAMP 3PAO judgement, agency ATO decisions, POA&M ownership
- SSP authorship and control parameter selection

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
AC-4 - Information Flow Enforcement	Direct	Policy workspace + workload-to-workload allowlist	Workspace snapshot + observed-vs-approved flow comparison
SC-7 - Boundary Protection (workload layer)	Direct	Default-deny policy at the workload boundary	Workspace snapshot showing boundary deny rules
AU family - Audit	Direct	Workload flow + process telemetry retained per retention policy	Retained telemetry export
SI-4 - System Monitoring	Direct	Continuous flow + process telemetry; alerts	Alert and anomaly log scoped to FedRAMP boundary
CA-7 - Continuous Monitoring	Direct	Continuous workspace + ADM + vulnerability evidence	Monthly evidence pack for ConMon submission
RA-5 / SI-2 - Vulnerability handling	Direct	Reachability-weighted CVE evidence	Prioritised remediation list with POA&M inputs

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Authorisation boundary inventory	Workloads inside the SSP boundary	Inventory + scope membership export	Monthly
Information-flow enforcement evidence	Workspace snapshot + violation log	Policy workspace export + policy analysis output	Monthly (ConMon cadence)
Continuous monitoring evidence	Workspace, ADM, and vulnerability inputs to ConMon	Aggregated monthly evidence pack	Monthly
Vulnerability + reachability	CVE list weighted by reach inside the boundary	Vulnerability report scoped to FedRAMP boundary	Monthly (per FedRAMP scanning cadence)
Incident sample	One representative	Flow + process	Per incident

Topic	What to collect	CSW source	Suggested cadence
	incident timeline for IR drills or actual incidents	search	

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. tenant, prototype, isa_level, np, cui, ephi).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not replace FedRAMP authorisation, SSP ownership, 3PAO assessment, CSP platform controls, identity layer (IAM / MFA), encryption (FIPS-validated modules), audit-log retention infrastructure, or agency ATO decisions.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.